Catalyst Works

FIELD GUIDE N° 01

VOL.
01

DATE
Apr 2026

PAGES
12

CLASS.
Public

AI Governance for the firm & the founder who *still runs it.*

WRITTEN BY

Boubacar Barry

Catalyst Works · April 2026

FOREWORD

THE FRAME

READ ONCE

TWELVE SECTIONS

BB / APR 26

Most AI problems are not AI problems. They are *clarity problems* that AI has exposed.

The leaders who handle AI well in 2026 will not be the ones with the deepest AI knowledge. They will be the ones who got clear on three things early. *What is in their stack. Who is accountable. How the firm decides.*

None of those questions are technical. All of them are operational.

This is a field guide for one specific person. Maybe you. She runs a firm of forty people. Could be sixty. Could be twenty-two. Some kind of professional services. A CPA practice in Salt Lake City. A regional law firm in Denver. A marketing agency that has grown faster than its operations.

She knows her firm cold. She did not start it to spend Tuesday nights reading the EU AI Act. But the questions arrive anyway. He runs a 35-person engineering firm in Boise. Same situation, different gender.

Their associates use ChatGPT for first drafts. The CRM added an AI module on by default. A prospective client asked, *"what is your AI governance policy?"* Nobody had a good answer.

They are not behind. They are exactly where most firms their size are.

The work has gotten ahead of the documentation.

I spent fifteen years inside firms across the US, the Middle East, Africa, and Europe. Watching where work actually slows down. This guide is the operator's lens. **Twelve sections. Read it once.**

01

SURFACE I

EMBEDDED AI

FROM THE FIELD

A MANAGING PARTNER

FORTY-FIVE EMPLOYEES

The CRM *already* decided.

Most firms discover their first major AI exposure inside a tool they have used for three years.

§ FROM THE FIELD

I sat across from a managing partner last quarter. Forty-five employees. He had been Googling AI governance for six weeks because his insurance broker asked him a question he could not answer.

I asked him to pull up his CRM admin panel. He had not logged in personally in eight months. We logged in together. Three AI features were on by default. All trained on his client communications since spring 2025.

He sat there for a minute. Then he said one thing.

"I had no idea."

Most firms bought a CRM in 2022. In late 2024 the vendor announced AI features. In early 2025 the features rolled out. Some required a click. Some did not.

The "did not" category is where the trouble lives.

It was decided in a release note. In a terms-of-service amendment that arrived on a Friday afternoon in August. By the default setting on a feature toggle in an admin panel nobody had logged into in six months.

The risk in 2026 is not what AI can do. It is what your team is already doing with it that nobody has written down.

The first job of governance is not to fix this. **The first job is to see it.**

02

THE DIAGNOSIS

THE VISIBLE GAP

A PATTERN FROM ≈ 40 FIRMS IN THE 20-200 RANGE

The *twelve-to-twenty* rule.

A firm with twenty employees usually has between twelve and twenty AI tools touching the business. The owner can typically name three.

FIRM SIZE	IN STACK	OWNER CAN NAME
20 employees	*12–15*	3
50 employees	*15–20*	3-5
100 employees	*20–30*	5-7
200 employees	*30–50*	7-10

The gap between the two columns is the diagnosis.

It is not a discipline problem. It is the natural drift of a fast-moving software market into a firm that runs on operating leverage. Vendors update terms. AI features get bundled. Defaults get flipped.

The owner sees the financial statements, not the feature flags.

The fix begins with one ninety-minute meeting that owners never schedule until something forces them to.

The firms that handle AI well make the meeting happen *before* the trigger.

The firms that handle it badly hold the meeting *during* the crisis.

03

WHERE RISK LIVES

THREE SURFACES

THREE DIFFERENT CONVERSATIONS

The three *surfaces*.

When something goes wrong involving AI inside a firm in your range, the source is almost always one of three places.

SURFACE 01

Shadow AI

Tools your team uses that nobody officially approved. Personal ChatGPT accounts. Free tier of Claude. A junior associate's Notion AI. A bookkeeper running QuickBooks AI categorization.

The first instinct is to treat this as a discipline problem. **Wrong move.** Shadow AI is not a discipline problem. *It is a workflow problem.*

The shadow AI you cannot see is more dangerous than the shadow AI you can.

SURFACE 02

Embedded AI

Software you bought before AI was a thing, that has since added AI features, often by default, often with vendor terms that allow training on your data unless you opt out within a window that has likely already closed.

This is the largest surface in most firms. It is also the one nobody thought about.

SURFACE 03

Vendor Blindspots

The AI inside tools you have not bought yet but are about to. New AI procurement happens faster than legal review can keep up. A department head finds a tool. Runs a free trial. Signs a contract.

The tool is in production before the firm has a record of approving it.

None require a CISO. All require the owner to know they exist.

04

THE TEST

ONE QUESTION

THREE THINGS HAPPEN, IN ORDER

The one question most firms *cannot answer*.

Pick the AI tool with the most exposure. The one with the most client data. For most firms it is the CRM or the email platform. Ask this question, out loud, with the people responsible for that tool.

"If this tool produced an error tomorrow that affected a client, who is the first call?"

Three things happen.

First: silence. The COO looks at the head of IT. The head of IT looks at the office manager. The office manager looks at the partner whose client was affected. Nobody answers.

Second: a half-answer. *"Well, it depends on what kind of error."* This is true. It is also a way of avoiding the question.

Third: a real answer. Somebody says *"I guess it would be me, because the vendor relationship is mine."* That answer is the start.

A map of accountability turns those answers into a single page. **Owner. Approver. First Responder.** Three names per major AI tool. The whole map fits on one sheet.

It is the conversation that determines whether the firm is *governed* or just *hopes to be*.

05

THE DOCUMENT
THE POLICY
THAT GETS USED

06
THE PRESSURE
INSURANCE,
CLIENTS,
AUDITORS, TODAY

The policy that *gets used*.

Most AI policies fail for one reason. *They are written for a lawyer to defend, not for an employee to use.*

The lawyer-defending policy reads like a treaty. Twelve clauses. EU AI Act citations. Fifteen pages. **Signed once, filed in SharePoint, never read again.**

The employee-using policy is two pages. Plain English. Seven categories. **Why the policy exists. Risk classification. Acceptable use. Data handling. Vendor procurement. Human oversight. Incident response.** An associate reads it in five minutes and knows what to do tomorrow.

The categories are simple. *The work is in the specifics.* Writing two pages an employee will follow takes more skill than writing fifteen pages that impress a lawyer.

What insurance, clients, and auditors are *asking*.

Regulations are slow. The pressure on owner-operator firms is faster.

Insurance carriers added AI questions to renewals in 2025. **Enterprise clients** are adding AI to vendor due diligence. **Auditors** ask: *"Show me your policy and the evidence that it is followed."*

If you cannot answer in writing within forty-eight hours, you lose to the firm that can.

07

THE LEGAL MAP

SIX LAWS

TO KNOW ABOUT

THE STATE LAWS CHANGE. THE FUNDAMENTALS DO NOT.

The regulations you *already live under*.

The honest answer to *"what laws apply to me?"* is **more than you think and less than you fear.**

LAW	IN FORCE	WHAT IT COVERS
Utah SB 149 AI Policy Act	*May 24*	First US state law on private-sector generative AI. Applies to anyone using GenAI to interact with people in Utah, regardless of where the firm is located.
Texas TRAIGA HB 149	*Jan 26*	Civil penalties up to **$200,000**/violation. *60-day cure period* if you have governance documentation.
Illinois HB 3773	*Jan 26*	Prohibits AI in employment decisions in ways that discriminate. Mandatory disclosure if AI is used in hiring, promotion, or termination.
Colorado SB 24-205	*Jun 26*	High-risk AI systems must use reasonable care to protect against algorithmic discrimination. Subject to revision.
EU AI Act	*2024-26*	Banned practices since Feb 2025. Fines up to **EUR 35M** or **7%** worldwide turnover.
NIST AI RMF	*Voluntary*	The defensible answer to *"how do you govern AI?"* points here. Voluntary is a legal status, not a recommendation to skip it.

08

THE DECISION

THREE TIERS

HONEST DECISION CRITERIA, NOT A SALES PITCH

When you *need help*.

Most of this work is doable inside the firm. Some of it is not.

TIER 01 / RUN IT YOURSELF

If the AI footprint is *small*.

Under fifteen tools. You have a head of operations who can own the rollout. You have legal counsel who can review the policy. **If all three are true, this guide is enough.**

TIER 02 / BRING IN A FRACTIONAL ADVISOR

If the work has *stalled*.

The footprint is sprawling and getting harder to track. A client has asked about AI governance in due diligence. Your insurance carrier added AI questions. You have employees in Utah, Texas, Illinois, or Colorado and have not addressed the state laws. The work has been on your to-do list for six months and not moved.

The fractional model is the right scale for most firms in your range. *Not because it is the most thorough. Because it is the right shape.*

TIER 03 / HIRE A FULL-TIME CISO

If the firm has *scaled past you*.

The firm has crossed two hundred employees. The regulatory exposure is multi-jurisdictional and high-stakes. The board is asking for a named accountable executive on AI.

09

THE OUTCOME

FIVE VIGNETTES

WHAT CHANGES WHEN THIS IS DONE WELL

What changes when this is *done well*.

01 The owner walks into the next insurance renewal and gives the broker the document. The broker files it. **Premium does not go up.**

02 The managing partner gets the next enterprise due diligence call. She has the answer in writing. **The contract closes faster.**

03 The associate who used to paste client data into ChatGPT now uses an approved tool with a different default behavior. The data does not leave the firm. **The output is roughly as good.**

04 A board member asks a hard question about AI risk. The owner has a one-page answer. **The board moves on.**

05 A new AI vendor pitches the firm. The head of operations runs them through a one-page review. The contract gets signed in two days. **The vendor knows the firm is serious about governance, and they bring their A-game.**

None of this is dramatic. *That is the point.*

AI governance done well is invisible.

The owner who has done this work feels different. **Not relieved. Confident.**

10

APPENDIX

SELF-RUN

DIAGNOSTIC

15 QUESTIONS

5 CATEGORIES

ANSWER IN WRITING

Fifteen *questions*.

The questions you cannot answer are the work.

A · CURRENT AI USAGE

01 Walk through every AI tool your team uses on a regular basis, including tools built into software you already use. Can you name them all?

02 Are there tools your employees are using informally, outside of anything you have officially approved?

03 Which of these tools touches client data, employee data, or proprietary business information?

B · RISK EXPOSURE

04 If one of your AI tools gave a client wrong information or made a discriminatory decision, what would happen? Who would handle it?

05 If a client asked you today how you use AI and what data protections you have in place, what would you say?

06 Are any of your clients in regulated industries? Do you know if your AI use creates compliance obligations for them?

C · EXISTING POLICIES

07 Do you have a written policy that governs how your team uses AI? Where does it live and when was it last updated?

08 What data are employees explicitly prohibited from inputting into AI tools?

09 If I asked one of your employees tomorrow what they are and are not allowed to do with AI, what would they say?

D · STAKEHOLDER ACCOUNTABILITY

10 If something goes wrong with an AI system tomorrow, who is the first call? Who owns the response?

11 Who in your firm has authority to approve or reject the adoption of a new AI tool?

12 If a regulator or auditor asked you to demonstrate responsible AI use, could you produce evidence within 48 hours?

E · VENDOR RELATIONSHIPS

13 Have you read the AI-specific data provisions in your vendor contracts? Does your vendor use your data to train their models?

14 Do you have a list of AI vendors your team is approved to use? Who maintains it?

15 When you evaluate a new AI software vendor, what specifically do you ask about their AI practices?

Your *move*.

IF YOU WANT TO TALK

The 20-minute Assessment Call.

We map the biggest AI risk surfaces in your stack. *No pitch.*

CALENDAR	calendly.com/boubacarbarry/ai-governance-assessment-call
ENGAGE	boubacar@catalystworks.consulting · for the deeper engagement
SPEAK	Same email. This material runs as a 30-min talk or a 60-min keynote.

If you have a COO, head of operations, or compliance lead in the firm, **forward them this guide.** The conversation gets shorter when you both have the same frame.

If you finish this guide and the work is clear, run it. Send me a note when you finish. The thing I learn most from is hearing how the patterns hold up against firms I have not worked with directly.

¶

CODA

A CLOSING OBSERVATION

READ ONCE

SIT WITH IT

A CLOSING OBSERVATION

The firm that wins on AI governance is the firm that already operated well. AI just made the question of how do you operate impossible to avoid.

This is true in 2026. It will be true in 2030.

It was probably true the whole time.

Boubacar Barry

CATALYST WORKS · APRIL 2026 · V.1

This guide is a starting point for governance documentation, not legal advice. Any policy affecting employee rights, client data, or regulatory compliance should be reviewed by qualified legal counsel. The author is not a lawyer. Free to share with attribution. Cannot be repackaged or sold.